INTERAFAS

Plan de Comunicación de Crisis

Entregable 4 — PR02-21 a PR02-30
Octubre 2026

1. Contexto de la crisis (PR02-21)

1.1 Escenario del incidente

Este plan toma como contexto el incidente reconstruido a partir de los hallazgos técnicos documentados en el Informe de Seguridad Ofensiva (INTERAFAS-LAB), presentado como un escenario realista de crisis de comunicación para INTERAFAS.

Narrativa del incidente. Un actor externo identifica, mediante enumeración de directorios del portal institucional (VULN-01), archivos de configuración residuales que exponen credenciales de la base de datos. A partir de ahí, explota una inyección SQL en el buscador de servicios (VULN-07) para extraer un volcado parcial de la base de datos, incluyendo expedientes de ciudadanos (nombre, domicilio, historial de consumo) y registros de facturación. Días después, el mismo actor aprovecha una falla de control de acceso en la API de pagos (VULN-12/VULN-13) para generar cargos fraudulentos. Simultáneamente, el atacante evade el perímetro de la red operacional (OT), mapea la topología de distribución de la planta por un exceso de privilegios (VULN-19) y logra instalar parámetros operativos maliciosos alterando los setpoints de presión físicos (VULN-18 y VULN-20), provocando una falla en cascada (Catastrophic State).

Afectaciones.

- Exposición de datos personales de un subconjunto de usuarios (nombre, domicilio, historial de consumo).
- Cargos de facturación fraudulentos en cuentas de un grupo de usuarios.
- Publicación en redes sociales y cobertura de un medio local antes de que INTERAFAS emitiera cualquier comunicado oficial.
- Especulación pública (no confirmada técnicamente) sobre si el incidente también comprometió la red operacional (agua/energía), dado que INTERAFAS es un organismo de infraestructura crítica.
- Sabotaje físico confirmado en la infraestructura crítica (red OT/SCADA) debido a la alteración maliciosa de parámetros operativos, interrumpiendo la disponibilidad del suministro y generando alarmas de estado catastrófico en la planta.

Escenario reputacional. El riesgo central no es solo técnico: es que la ciudadanía se entere del incidente por redes sociales y prensa antes que por la propia INTERAFAS, situación agravada por la confirmación técnica de que la infraestructura operativa física (agua/energía) fue exitosamente saboteada (VULN-18 a VULN-20). Este plan existe para que INTERAFAS controle el relato con información oportuna, precisa y consistente, manejando la crisis de interrupción de servicio sin comprometer la investigación técnica en curso.

1.2 Relación con otros entregables del proyecto

Este plan se activa cuando el Plan de Respuesta ante Incidentes (entregable 5) clasifica un evento como incidente de seguridad con impacto en la confianza pública, y se apoya en el inventario de activos, políticas funcionales y matriz de riesgos del entregable 3 (Secciones 04 a 06), en particular los riesgos R-02 (exposición de PII), R-06 (fraude en pagos), R-16 (crisis reputacional por cobertura mediática), R-21 (falsificación de firmware OT), R-22 (exposición de topología) y R-23 (sabotaje de parámetros operativos).

2. Comité de Crisis y roles (PR02-22)

2.1 Comité de Crisis

El Comité de Crisis se activa cuando el Plan de Respuesta ante Incidentes clasifica el evento como incidente de seguridad con impacto en la confianza pública. Su composición y responsabilidades se detallan a continuación.

Rol	Responsable	Función en la comunicación
Líder del Comité	Director General	Aprueba los comunicados oficiales y decide el nivel de escalamiento.
Vocero oficial	Director de Comunicación	Emite los mensajes públicos y gestiona la relación con medios.
Coordinador técnico	CISO / Responsable de Seguridad	Valida el contenido técnico de los comunicados y aporta hechos verificados.
Asesor jurídico	Director Jurídico	Revisa el contenido legal y de protección de datos antes de su emisión.

Enlace con autoridades	Director de Relaciones Institucionales	Coordina la comunicación con reguladores y autoridades competentes.
Enlace con usuarios	Director de Atención al Ciudadano	Gestiona los canales de atención y las notificaciones a afectados.

2.2 Protocolo de activación

El Comité se convoca de forma inmediata cuando se confirma un incidente con impacto en la confianza pública. La primera reunión debe realizarse en un plazo no mayor a 60 minutos desde la activación.

3. Canales y públicos (PR02-23)

3.1 Públicos prioritarios

- Usuarios afectados directamente (notificación individual prioritaria).
- Ciudadanía en general (comunicación institucional).
- Medios de comunicación locales y nacionales.
- Autoridades reguladoras y de protección de datos.
- Empleados y proveedores clave.

3.2 Canales oficiales

Portal institucional, redes sociales oficiales, centro de atención telefónica, comunicado de prensa y notificación directa a usuarios afectados.

4. Principios de comunicación (PR02-24)

- Oportunidad: comunicar tan pronto como se tenga información verificada.
- Precisión: solo hechos confirmados; evitar especulación.
- Consistencia: un solo mensaje oficial a través de todos los canales.
- Transparencia: informar lo que se sabe y lo que se está investigando.
- Empatía: reconocer el impacto en los usuarios afectados.

5. Niveles de escalamiento (PR02-25)

Nivel 1 – Incidente contenido: comunicación interna y notificación a afectados directos.

Nivel 2 – Incidente con cobertura mediática: activación del vocero y primer comunicado público.

Nivel 3 – Crisis reputacional: rueda de prensa y seguimiento intensivo de medios.

Nivel 4 – Crisis con impacto operacional o regulatorio: coordinación con autoridades y mensaje institucional ampliado.

6. Mensajes por etapa (PR02-26)

6.1 Holding Statement (hora cero)

"INTERAFAS está investigando un incidente de seguridad que afecta a un subconjunto de usuarios. Estamos trabajando para determinar el alcance y tomaremos las medidas necesarias para proteger la información y los intereses de nuestros usuarios. Emitiremos actualizaciones conforme avancemos en la verificación."

6.2 Comunicado de actualización

Se emite cuando se confirma el alcance del incidente. Incluye: qué ocurrió, a quién afecta, qué medidas se están tomando y qué deben hacer los usuarios.

6.3 Preguntas frecuentes

Pregunta	Respuesta
¿Mis datos fueron comprometidos?	Estamos verificando el alcance exacto. Los usuarios afectados serán notificados de forma individual.
¿Por qué no comunicaron antes?	Nuestro primer comunicado se emitió el tiempo necesario para verificar la información antes de comunicarla con responsabilidad.
¿Qué están haciendo para que no vuelva a pasar?	Implementamos controles de seguridad de la información alineados a la norma ISO/IEC 27001.
¿Me van a devolver mi dinero si me cobraron de más?	Sí, todo cargo indebido identificado será revertido en su totalidad.

7. Monitoreo de medios y redes (PR02-27)

Se establece un monitoreo continuo de menciones a INTERAFAS en medios y redes sociales durante las primeras 72 horas, con reportes cada 4 horas al Comité de Crisis.

8. Notificación a usuarios afectados (PR02-28)

Los usuarios afectados reciben notificación individual por los canales registrados (correo electrónico y/o mensaje en el portal), con instrucciones claras sobre los pasos a seguir.

9. Coordinación con autoridades (PR02-29)

Se notifica a las autoridades competentes conforme a los plazos legales aplicables, manteniendo la coherencia entre la comunicación pública y la información compartida con reguladores.

10. Evaluación posterior (PR02-30)

10.1 Indicadores de desempeño de la comunicación de crisis

Indicador	Meta	Cómo se mide
Tiempo hasta el primer comunicado oficial	≤ 4 horas desde la confirmación del incidente	Marca de tiempo del holding statement vs. hora de confirmación técnica
Proporción de cobertura mediática/redes con tono negativo	Tendencia descendente tras cada comunicado	Reportes de monitoreo de medios
Volumen de consultas a los canales de atención	Capacidad de respuesta sin tiempos de espera excesivos	Reportes del Centro de Atención Telefónica
Tasa de usuarios notificados vs. usuarios afectados	100%	Comparación entre padrón de afectados y registro de notificaciones
Consistencia del mensaje entre canales	0 contradicciones detectadas	Revisión posterior de todos los mensajes emitidos

10.4 Lecciones aprendidas

Pregunta guía	Hallazgo (a documentar al cierre de cada crisis real)
¿Qué funcionó bien en la respuesta de comunicación?	—
¿Qué retrasó la emisión del primer comunicado?	—
¿Qué información hubiéramos necesitado antes de TI/Jurídico?	—
¿Qué canal tuvo mejor u peor desempeño para llegar a los afectados?	—
¿Qué cambios se incorporan a este plan para la próxima crisis?	—